

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA CÔNG NGHỆ THÔNG TIN 1



BÁO CÁO: AN TOÀN BẢO MẬT VÀ HỆ THỐNG THÔNG TIN
ĐỀ TÀI: TÌM HIỂU VỀ CÁC DẠNG TẤN CÔNG DoS và
DDoS

NHÓM THỰC HIỆN: G0803

THÀNH VIÊN NHÓM

Nguyễn Duy Hà	B22DCCN256
Nguyễn Việt Thắng	B22DCCN815
Đinh Quốc Việt	B22DCCN895
Hồ Lý Đức	B22DCCN226
Nguyễn Bích Ngọc	B22DCCN587

GIẢNG VIÊN HƯỚNG DẪN: Đinh Trường Duy

HÀ NỘI, 4/2025

Mục Lục

1. Giới thiệu:	3
2. Nội dung	3
2.1 Kiến trúc tấn công	3
2.2 Giải thuật và Cơ chế (các kỹ thuật tấn công DoS/DDoS phổ biến)	8
2.3 Các điểm yếu bị khai thác (phân tích điểm yếu trong các tầng giao thức)	8
2.4 Phân loại các dạng trong tấn công (phân loại và mô tả các loại tấn công)	10
2.5 Các ứng dụng trong thực tế (Ví dụ thực tế)	13
2.6 Phòng chống thực tiễn	14
2.7 Công cụ minh họa và so sánh	16
3. Kết luận	19
4. Tài liệu tham khảo	20

1. Giới thiệu:

Trong bối cảnh thế giới ngày càng phụ thuộc vào các hệ thống thông tin và dịch vụ trực tuyến, đảm bảo tính **sẵn sàng (availability)** của hệ thống trở thành một yếu tố sống còn trong an ninh mạng. Tuy nhiên, đây cũng chính là điểm yếu dễ bị khai thác bởi một trong những hình thức tấn công phổ biến và nguy hiểm nhất hiện nay – **Tấn công từ chối dịch vụ (DoS)** và **Tấn công từ chối dịch vụ phân tán (DDoS)**.

Tấn công DoS/DDoS không nhằm chiếm đoạt dữ liệu hay truy cập trái phép mà hướng tới **làm gián đoạn hoặc ngừng hoàn toàn hoạt động** của dịch vụ, ứng dụng hoặc hạ tầng mạng bằng cách tiêu tốn hoặc làm cạn kiệt tài nguyên hệ thống. Từ đó, người dùng hợp pháp không thể truy cập vào các dịch vụ, gây thiệt hại lớn về kinh tế, uy tín và vận hành doanh nghiệp.

Trong đề tài này, nhóm sẽ tập trung phân tích chi tiết về:

- Kiến trúc và cơ chế hoạt động của các loại tấn công DoS và DDoS.
- Các kỹ thuật tấn công phổ biến (Flooding, Exhaustion, Amplification).
- Những điểm yếu trong tầng giao thức và ứng dụng bị khai thác.
- Phân loại các dạng tấn công theo cấp độ và mục tiêu.
- Công cụ minh họa thực tế.
- Ví dụ các vụ tấn công quy mô lớn trên thế giới.
- Các biện pháp phòng chống hiệu quả trong thực tiễn.

Mục tiêu của báo cáo là **giúp người đọc hiểu rõ bản chất, cơ chế và ảnh hưởng của tấn công DoS/DDoS**, từ đó đề xuất các giải pháp phù hợp để nâng cao khả năng phòng vệ và đảm bảo sự ổn định cho hệ thống thông tin trong doanh nghiệp và tổ chức.

2. Nội dung

2.1 Kiến trúc tấn công

1. Tấn công từ chối dịch vụ (DoS)

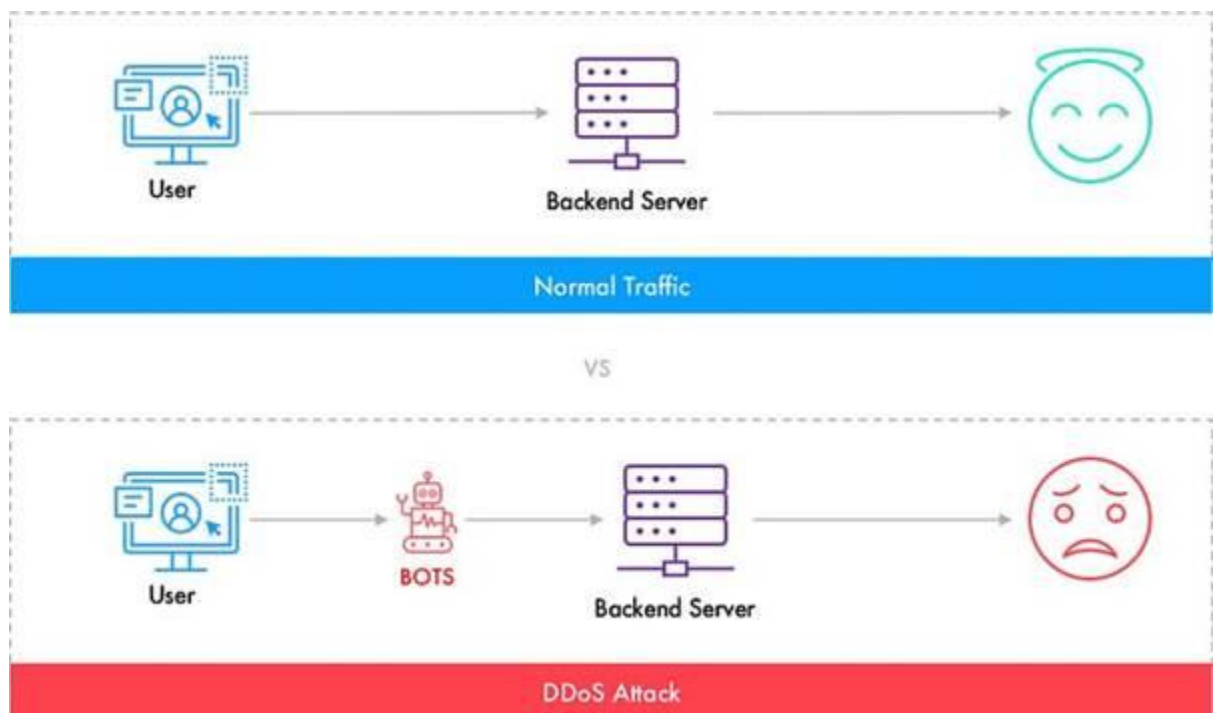
Tấn công từ chối dịch vụ (Denial of Service - DoS) là một trong những hình thức tấn công phổ biến và nguy hiểm trong lĩnh vực an ninh mạng hiện nay. Đây là một hành vi cố ý được thực hiện bởi các đối tượng xấu nhằm làm gián đoạn hoạt động bình thường của một dịch vụ, máy chủ hoặc hệ thống mạng. Mục tiêu của tấn công DoS là làm cho các tài nguyên hệ thống như CPU, bộ nhớ, băng thông hoặc dịch vụ phần mềm trở nên quá tải, dẫn đến việc người dùng hợp pháp không thể truy cập hoặc sử dụng hệ thống một cách bình thường.

Cách thức hoạt động của cuộc tấn công DoS thường khá đơn giản nhưng lại hiệu quả. Một thiết bị duy nhất hoặc một mạng do kẻ tấn công kiểm soát sẽ gửi một lượng lớn yêu cầu hoặc gói tin tới mục tiêu nhằm tiêu tốn tài nguyên của hệ thống. Khi số lượng yêu cầu vượt quá khả năng xử lý của hệ thống, dịch vụ sẽ bị chậm, phản hồi kém, hoặc thậm chí dừng hoạt động hoàn toàn.

Các loại tấn công DoS:

- **Tấn công theo khối lượng:** Đây là hình thức tấn công phổ biến nhất, trong đó kẻ tấn công tìm cách làm bão hòa băng thông của hệ thống mục tiêu bằng cách gửi một lượng lớn lưu lượng truy cập đến đó. Các gói dữ liệu giả mạo hoặc các yêu cầu không cần phản hồi được gửi với tốc độ cao, khiến đường truyền mạng bị nghẽn. Khi băng thông bị chiếm dụng hoàn toàn, các yêu cầu hợp pháp từ người dùng thật không thể đi qua, dẫn đến dịch vụ bị gián đoạn hoặc không thể truy cập.
- **Tấn công giao thức:** Kiểu tấn công này nhằm vào các điểm yếu trong giao thức mạng, chẳng hạn như TCP, IP, ICMP hoặc ARP. Kẻ tấn công khai thác các lỗ hổng trong cách hệ thống xử lý kết nối, như trong tấn công SYN Flood – nơi hệ thống mục tiêu bị làm đầy bởi các yêu cầu kết nối chưa hoàn tất. Những tấn công này không yêu cầu lượng lớn lưu lượng mà thay vào đó sử dụng cơ chế vận hành của giao thức để làm tiêu tốn tài nguyên như băng kết nối, bộ đệm hoặc CPU, từ đó khiến hệ thống phản hồi chậm hoặc bị treo.
- **Tấn công tầng ứng dụng:** Đây là loại tấn công tinh vi hơn, tập trung vào tầng ứng dụng – nơi tương tác trực tiếp với người dùng, chẳng hạn như trình duyệt web, máy chủ HTTP, hoặc hệ thống quản lý cơ sở dữ liệu. Kẻ tấn công gửi hàng loạt yêu cầu có vẻ hợp pháp nhưng được thiết kế để tiêu tốn tối đa tài nguyên xử lý của ứng dụng, ví dụ như yêu cầu tìm kiếm, truy vấn dữ liệu phức tạp, hoặc gửi biểu mẫu liên tục. Mục tiêu của tấn công là khiến ứng dụng bị quá tải, hoạt động chậm chạp hoặc ngừng hoạt động hoàn toàn, ảnh hưởng trực tiếp đến trải nghiệm người dùng và khả năng vận hành dịch vụ.

2. Tấn công từ chối dịch vụ phân tán (DDoS)



Tấn công từ chối dịch vụ phân tán (Distributed Denial of Service - DDoS) là một hình thức tấn công phức tạp và nguy hiểm hơn tấn công DoS. Điểm khác biệt cơ bản của DDoS nằm ở nguồn gốc tấn công. Thay vì đến từ một thiết bị duy nhất, các cuộc tấn công DDoS được tiến hành từ

hàng trăm, thậm chí hàng triệu thiết bị khác nhau trên toàn cầu. Những thiết bị này đã bị xâm nhập và kiểm soát từ trước, tạo thành một mạng lưới gọi là botnet. Botnet có thể bao gồm các máy tính cá nhân, máy chủ, thiết bị IoT, điện thoại thông minh, hay thậm chí là camera giám sát thông minh.

Kẻ tấn công sẽ điều khiển toàn bộ botnet gửi lưu lượng truy cập hoặc yêu cầu đồng loạt tới mục tiêu, khiến hệ thống đích không thể phân biệt được đâu là người dùng hợp pháp và đâu là lưu lượng độc hại. Vì các cuộc tấn công DDoS được thực hiện đồng thời từ nhiều nguồn phân tán, chúng có khả năng gây thiệt hại nghiêm trọng trong thời gian ngắn và rất khó để phát hiện hoặc ngăn chặn bằng các biện pháp phòng vệ truyền thống.

Các loại tấn công DDoS:

- **Các cuộc tấn công dựa trên lưu lượng:** Bao gồm tấn công UDP, tấn công ICMP và tấn công SYN, nhằm mục đích làm quá tải băng thông của mục tiêu. Những cuộc tấn công này tập trung vào việc tạo ra một lượng lớn dữ liệu giả mạo để tràn ngập hệ thống mạng, khiến cho các dịch vụ hợp pháp không thể hoạt động bình thường. Lưu lượng lớn này có thể làm nghẽn hoàn toàn khả năng truyền tải dữ liệu của hệ thống, dẫn đến hiện tượng nghẽn mạng hoặc ngắt kết nối.
- **Tấn công ở tầng ứng dụng:** Các cuộc tấn công như tấn công tràn HTTP hoặc khuếch đại DNS làm quá tải tầng ứng dụng, khiến chúng khó bị phát hiện hơn vì chúng bắt chước lưu lượng truy cập hợp pháp. Những cuộc tấn công này nhắm vào các dịch vụ cụ thể mà người dùng thường xuyên truy cập như trang web, cơ sở dữ liệu hoặc các API. Bằng cách gửi hàng loạt yêu cầu có vẻ hợp lệ nhưng thực chất nhằm tiêu tốn tài nguyên xử lý, các cuộc tấn công này khiến ứng dụng bị chậm lại hoặc ngừng hoạt động.
- **Tấn công khuếch đại:** Sử dụng các kỹ thuật phản xạ, trong đó các yêu cầu nhỏ sẽ dẫn đến phản hồi lớn, khuếch đại tác động của cuộc tấn công. Kẻ tấn công sẽ gửi các gói tin nhỏ đến các máy chủ trung gian như máy chủ DNS hoặc NTP, với địa chỉ IP giả mạo là địa chỉ của nạn nhân. Các máy chủ này sau đó sẽ phản hồi bằng một lượng dữ liệu lớn tới mục tiêu, làm gia tăng khối lượng tấn công lên nhiều lần so với lượng dữ liệu ban đầu, khiến mục tiêu nhanh chóng bị quá tải.

3. Phân biệt Tấn công DoS và Tấn công DDoS

Khía cạnh	DoS	DDoS
Nguồn tấn công	Từ một hệ thống hoặc thiết bị duy nhất.	Nhiều hệ thống bị chiếm quyền điều khiển (botnet).
Độ phức tạp	Đơn giản, dễ thực hiện và dễ phát hiện.	Phức tạp, khó truy vết và ngăn chặn.

Tốc độ ảnh hưởng	Tương đối chậm, ảnh hưởng từ từ.	Gây ảnh hưởng nhanh và mạnh do nhiều nguồn tấn công đồng thời.
Quy mô	Giới hạn bởi khả năng của một kẻ tấn công, quy mô nhỏ.	Quy mô lớn nhờ nhiều nguồn phân tán, có thể lan rộng nhanh chóng.
Khả năng phát hiện	Dễ dàng phát hiện, nguồn tấn công chỉ từ một hệ thống duy nhất.	Khó phát hiện do có nhiều nguồn tấn công khác nhau và phân tán.
Biện pháp giảm thiểu	Dễ chặn nguồn tấn công và xác định được thủ phạm.	Đòi hỏi các cơ chế phòng thủ phức tạp như phân tích lưu lượng và lọc IP.

4. Kiến trúc cơ bản của tấn công DoS/DDoS

Tấn công DoS (Denial of Service) và DDoS (Distributed Denial of Service) đều nhằm mục đích gây gián đoạn hoặc làm tê liệt các dịch vụ mạng hoặc máy chủ, khiến cho dịch vụ không thể cung cấp cho người dùng hợp pháp. Tuy nhiên, kiến trúc của tấn công DDoS phức tạp hơn rất nhiều so với DoS vì nó bao gồm nhiều nguồn tấn công phân tán.

a. Thành phần chính trong kiến trúc tấn công

Kẻ tấn công (Attacker): Kẻ tấn công là người điều phối và phát động cuộc tấn công. Trong trường hợp của một cuộc tấn công DoS, kẻ tấn công sẽ sử dụng một hệ thống hoặc thiết bị để gây quá tải cho mục tiêu. Tuy nhiên, trong trường hợp của tấn công DDoS, kẻ tấn công sẽ điều khiển một mạng lưới các thiết bị bị xâm nhập (botnet) để phát động cuộc tấn công. Kẻ tấn công có thể hoạt động từ xa hoặc thông qua các giao diện điều khiển từ xa để chỉ đạo các botnet thực hiện tấn công đồng thời.

Botnet: Botnet là mạng lưới các thiết bị bị nhiễm mã độc và bị chiếm quyền điều khiển bởi kẻ tấn công. Các thiết bị trong botnet có thể bao gồm máy tính, thiết bị IoT (Internet of Things), camera IP, máy chủ, và các thiết bị khác có thể kết nối với mạng. Các thiết bị này sẽ hoạt động như những "zombie" và thực hiện các yêu cầu tấn công theo lệnh của kẻ tấn công. Botnet có thể bao gồm hàng nghìn hoặc thậm chí hàng triệu thiết bị bị nhiễm, giúp kẻ tấn công phân tán tải tấn công và làm cho cuộc tấn công trở nên mạnh mẽ và khó bị ngăn chặn.

Mục tiêu (Target): Mục tiêu của tấn công DoS/DDoS có thể là máy chủ, dịch vụ, hoặc hệ thống mạng mà kẻ tấn công muốn làm cho nó không khả dụng hoặc ngừng phục vụ người dùng hợp pháp. Các mục tiêu phổ biến của tấn công DoS/DDoS bao gồm các máy chủ web, cơ sở dữ liệu, các dịch vụ trực tuyến như dịch vụ email, hệ thống DNS, hoặc các ứng dụng khác. Tấn công có thể nhắm vào một dịch vụ cụ thể hoặc toàn bộ hệ thống, làm cho dịch vụ không thể tiếp tục hoạt động.

b. Quy trình tấn công DDoS điển hình

Quy trình của một cuộc tấn công DDoS có thể được chia thành ba giai đoạn chính: Giai đoạn chuẩn bị, giai đoạn tấn công và giai đoạn sụp đổ.

Giai đoạn chuẩn bị: Trong giai đoạn chuẩn bị, kẻ tấn công sẽ xây dựng một botnet để thực hiện cuộc tấn công. Việc xây dựng botnet thường được thực hiện thông qua việc phát tán phần mềm độc hại (malware), chẳng hạn như Trojan hoặc worm, lên các thiết bị mục tiêu. Khi các thiết bị này bị nhiễm mã độc, chúng sẽ tự động trở thành một phần của botnet và sẵn sàng thực hiện các yêu cầu tấn công khi được ra lệnh. Ngoài ra, trong giai đoạn này, kẻ tấn công cũng có thể tiến hành quét lỗ hổng trên các thiết bị IoT hoặc máy tính yếu, tìm kiếm các thiết bị dễ bị xâm nhập để thêm vào botnet.

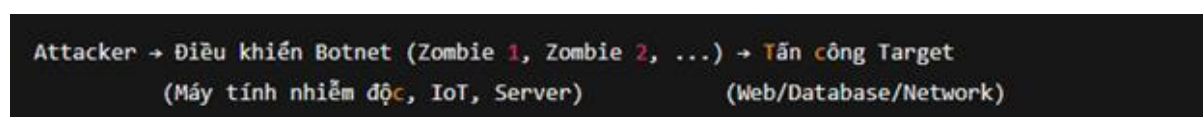
Giai đoạn tấn công: Sau khi đã xây dựng botnet thành công, kẻ tấn công sẽ ra lệnh cho botnet đồng loạt gửi các yêu cầu tấn công đến mục tiêu. Các phương thức tấn công DDoS phổ biến bao gồm:

- **SYN Flood:** Kẻ tấn công gửi hàng loạt các gói TCP SYN không hoàn tất đến máy chủ mục tiêu. Điều này khiến máy chủ phải chờ đợi các kết nối không bao giờ hoàn thành, dẫn đến việc tiêu tốn tài nguyên của hệ thống.
- **HTTP Flood:** Đây là tấn công HTTP, trong đó botnet gửi một lượng lớn yêu cầu HTTP đến máy chủ web. Máy chủ phải xử lý tất cả các yêu cầu này, làm cho tài nguyên của máy chủ bị quá tải và dẫn đến gián đoạn dịch vụ.
- **DNS Amplification:** Kẻ tấn công lợi dụng các máy chủ DNS để gửi một yêu cầu nhỏ nhưng nhận được phản hồi lớn. Phản hồi này sẽ được chuyển tiếp đến mục tiêu, gây quá tải băng thông và làm gián đoạn dịch vụ.

Giai đoạn sụp đổ: Cuối cùng, khi các yêu cầu tấn công từ botnet tiếp tục tấn công vào mục tiêu, hệ thống hoặc dịch vụ sẽ bị quá tải. Lúc này, các tài nguyên của hệ thống, như bộ nhớ, CPU và băng thông, sẽ không thể đáp ứng đủ các yêu cầu hợp lệ từ người dùng hợp pháp, dẫn đến việc dịch vụ ngừng hoạt động hoặc hoạt động chậm chạp, không ổn định. Hệ thống có thể bị tê liệt hoàn toàn và không thể phục vụ người dùng.

c. Sơ đồ kiến trúc tấn công

Dưới đây là sơ đồ kiến trúc cơ bản của một cuộc tấn công DDoS điển hình:



- **Attacker:** Kẻ tấn công điều khiển và chỉ đạo các thiết bị bị nhiễm (botnet) để phát động tấn công.
- **Botnet:** Mạng lưới các thiết bị bị xâm nhập và điều khiển (có thể là máy tính cá nhân, thiết bị IoT, máy chủ bị nhiễm mã độc).
- **Target:** Mục tiêu của cuộc tấn công, có thể là máy chủ web, cơ sở dữ liệu, mạng hoặc bất kỳ dịch vụ trực tuyến nào.

2.2 Giải thuật và Cơ chế (các kỹ thuật tấn công DoS/DDoS phổ biến)

1. Flooding (Tấn công Gây ngập lụt)

- **Mục đích:** Làm tê liệt hệ thống bằng cách gửi lượng lớn lưu lượng đến mục tiêu, vượt quá khả năng xử lý.
- **Ví dụ:**
 - **SYN Flood:** Gửi hàng loạt gói tin TCP SYN (yêu cầu thiết lập kết nối) nhưng không hoàn tất quá trình bắt tay ba bước, khiến server quá tải.
 - **UDP Flood:** Khai thác giao thức UDP không trạng thái, gửi nhiều gói tin đến cổng ngẫu nhiên, buộc server phản hồi "ICMP Destination Unreachable".
 - **ICMP Flood:** Dùng lệnh ping (ICMP Echo Request) liên tục để làm ngập băng thông mạng.

2. Exhaustion (Tấn công Cạn kiệt Tài nguyên)

- **Mục đích:** Tiêu thụ tài nguyên hệ thống (CPU, bộ nhớ, băng thông) để ngăn dịch vụ hoạt động.
- **Ví dụ:**
 - **SYN Flood (kết hợp Flooding và Exhaustion):** Mỗi gói SYN chiếm dụng bộ nhớ server để lưu trạng thái kết nối. Hàng nghìn SYN giả mạo làm đầy bảng kết nối.
 - **HTTP Slowloris:** Duy trì kết nối HTTP mở bằng cách gửi từng phần header chậm rãi, chiếm dụng tất cả luồng xử lý của server.
 - **TCP Connection Exhaustion:** Tạo nhiều kết nối TCP đồng thời để server không thể đáp ứng người dùng thực.

3. Amplification (Tấn công Khuếch đại)

- **Mục đích:** Lợi dụng giao thức có tỷ lệ phản hồi lớn hơn yêu cầu, dùng máy chủ hợp pháp làm "vật trung gian" để khuếch đại lưu lượng tấn công.
- **Ví dụ:**
 - **DNS Amplification:** Gửi truy vấn DNS giả mạo địa chỉ nguồn (IP của nạn nhân). Phản hồi DNS (lớn hơn 50 lần yêu cầu) sẽ tràn ngập mục tiêu.
 - **NTP Amplification:** Khai thác máy chủ NTP (Network Time Protocol) trả về danh sách lớn địa chỉ IP khi nhận lệnh monlist.
 - **SNMP Amplification:** Sử dụng giao thức SNMP để thu thập thông tin mạng với phản hồi kích thước lớn.

2.3 Các điểm yếu bị khai thác (phân tích điểm yếu trong các tầng giao thức)

1. Tầng Mạng (IP/ICMP)

- **IP Spoofing:** Giao thức IP không xác thực địa chỉ nguồn, cho phép kẻ tấn công giả mạo IP để che giấu nguồn gốc hoặc thực hiện Reflection/Amplification.

- **ICMP Vulnerabilities:** Giao thức ICMP (dùng cho ping) không yêu cầu thiết lập kết nối, dễ bị lợi dụng trong ICMP Flood hoặc Smurf Attack (gửi ping đến địa chỉ broadcast mạng với IP nguồn giả mạo).

2. Tầng Giao vận (TCP/UDP)

- **TCP Three-Way Handshake:** Quá trình bắt tay ba bước tạo ra trạng thái kết nối trên server. SYN Flood khai thác điểm yếu này bằng cách gửi SYN liên tục mà không hoàn thành ACK.
- **UDP Connectionless:** Không có cơ chế xác nhận hoặc quản lý kết nối, khiến UDP Flood dễ dàng thực hiện với gói tin giả mạo.

3. Tầng ứng dụng (HTTP/DNS)

- **HTTP Keep-Alive và Timeouts:**
 - Server thường duy trì kết nối mở để tối ưu hiệu suất, nhưng Slowloris lợi dụng điều này để chiếm dụng kết nối.
 - Cấu hình timeouts không hợp lý cho phép kẻ tấn công kéo dài thời gian chờ.
- **DNS UDP và Recursive Queries:**
 - DNS sử dụng UDP, dễ bị giả mạo địa chỉ nguồn.
 - Máy chủ DNS mở (open resolvers) cho phép truy vấn đệ quy từ bất kỳ IP nào, trở thành công cụ cho Amplification Attack.

4. NTP (Network Time Protocol)

- **Amplification Attack (NTP Monlist):**
 - Một số phiên bản NTP cũ hỗ trợ lệnh monlist (yêu cầu danh sách các client gần nhất từ máy chủ). Kẻ tấn công có thể giả mạo IP nguồn (spoofing) và gửi yêu cầu monlist đến các máy chủ NTP mở, khiến máy chủ phản hồi danh sách lớn (gấp 556 lần kích thước gói gửi đi), gây **DDoS Reflection/Amplification**.
 - **Ví dụ:** Tấn công khuếch đại qua NTP chiếm 14% tổng số DDoS năm 2022 (theo Cloudflare).
- **Thiếu xác thực nguồn gốc:**
 - NTP phiên bản cũ (trước v4) không yêu cầu xác thực khi đồng bộ thời gian. Kẻ tấn công có thể giả mạo máy chủ NTP để điều chỉnh sai thời gian trên hệ thống mục tiêu, ảnh hưởng đến SSL certificates, log hệ thống, hoặc giao dịch tài chính.
- **Lỗi phiên bản cũ:**
 - Các lỗ hổng như CVE-2016-7434 cho phép kẻ tấn công thực thi mã từ xa trên máy chủ NTP chưa vá.

5. SNMP (Simple Network Management Protocol)

- **Community String mặc định:**
 - SNMP sử dụng chuỗi "community" (như mật khẩu) để xác thực. Nhiều thiết bị mạng giữ nguyên giá trị mặc định (ví dụ: public cho read-only, private cho read-

write), cho phép kẻ tấn công truy cập thông tin nhạy cảm (cấu hình mạng, trạng thái thiết bị).

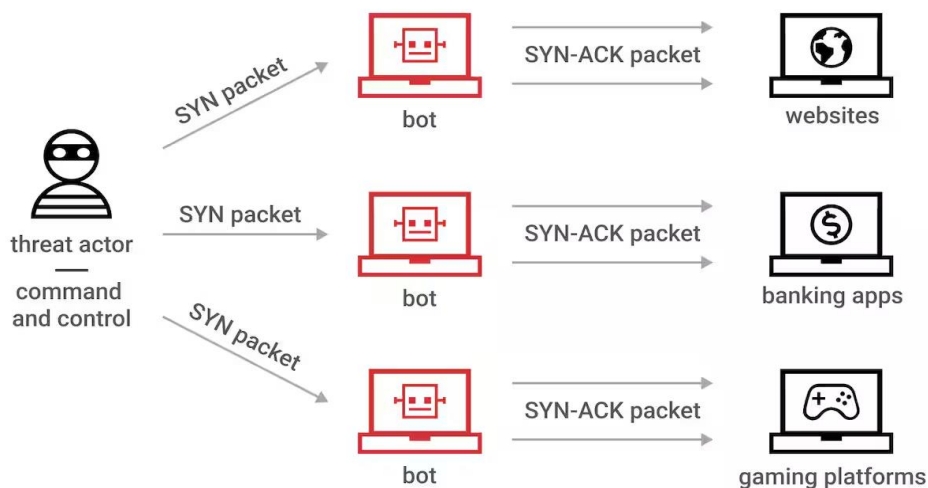
- **Giao thức UDP không an toàn:**
 - SNMP chủ yếu dùng UDP (không có cơ chế xác nhận), dễ bị **spoofing** hoặc **replay attack**. Kẻ tấn công có thể chặn và sửa đổi gói tin SNMP để thay đổi cấu hình thiết bị (ví dụ: tắt firewall).
- **Thông tin nhạy cảm bị lộ:**
 - SNMP cho phép truy vấn thông tin hệ thống (phiên bản OS, tiến trình đang chạy) qua OID (Object Identifier). Nếu SNMP không được cấu hình chặt chẽ, kẻ tấn công có thể thu thập dữ liệu để chuẩn bị cho tấn công nâng cao (lateral movement).
- **SNMP Trap/Inform Spoofing:**
 - Kẻ tấn công có thể gửi cảnh báo giả (Trap/Inform) đến hệ thống giám sát, gây nhiễu hoặc che giấu hành vi độc hại.

2.4 Phân loại các dạng trong tấn công (phân loại và mô tả các loại tấn công)

1. SYN Flood

- **Mô tả:**

SYN Flood là một loại tấn công từ chối dịch vụ (DoS/DDoS) nhắm vào giao thức TCP. Trong quá trình bắt tay ba bước (three-way handshake) của TCP, kẻ tấn công gửi một lượng lớn gói tin SYN (yêu cầu kết nối) đến máy chủ mục tiêu mà không hoàn tất bước cuối (gửi ACK). Điều này khiến máy chủ giữ các kết nối "nửa mở" (half-open), làm cạn kiệt tài nguyên (bộ nhớ, bảng kết nối) và khiến máy chủ không thể xử lý các yêu cầu hợp lệ.
- **Cơ chế:**
 - Gửi gói SYN với địa chỉ IP giả mạo (spoofed IP).
 - Máy chủ phản hồi bằng SYN-ACK nhưng không nhận được ACK, dẫn đến tình trạng treo tài nguyên.
- **Hình ảnh minh họa:**



What is a DDoS attack? – SYN-ACK Reflection Attack



2. UDP Flood

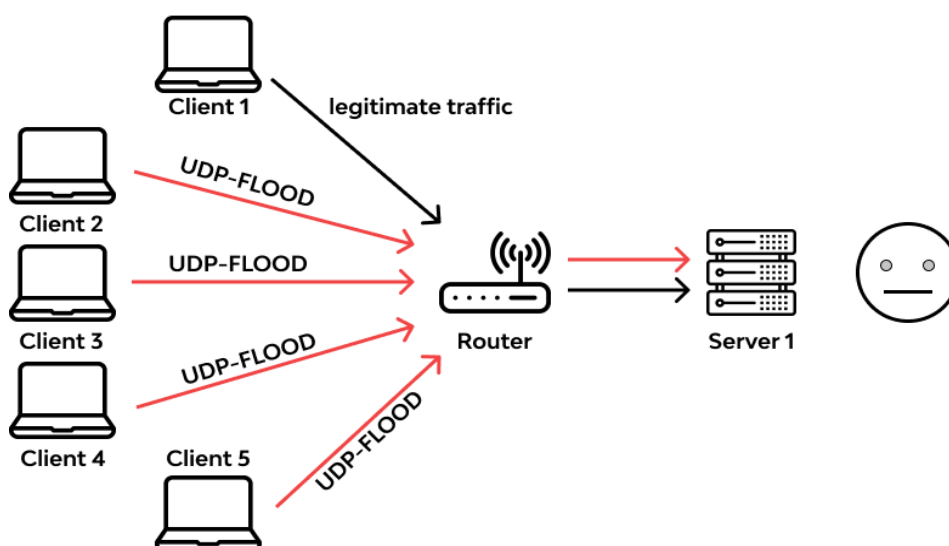
- **Mô tả:**

UDP Flood là một cuộc tấn công DDoS tận dụng giao thức UDP (User Datagram Protocol) – một giao thức không kết nối. Kẻ tấn công gửi một lượng lớn gói tin UDP đến các cổng ngẫu nhiên trên máy chủ mục tiêu. Máy chủ phải kiểm tra từng cổng, trả lời bằng gói ICMP "Destination Unreachable" nếu cổng không mở, dẫn đến quá tải băng thông và tài nguyên.

- **Cơ chế:**

- Không yêu cầu bắt tay như TCP, dễ dàng gửi số lượng lớn gói tin.
- Có thể kết hợp với IP giả mạo để tăng độ ẩn danh.

- **Hình ảnh minh họa:**



3. HTTP Flood

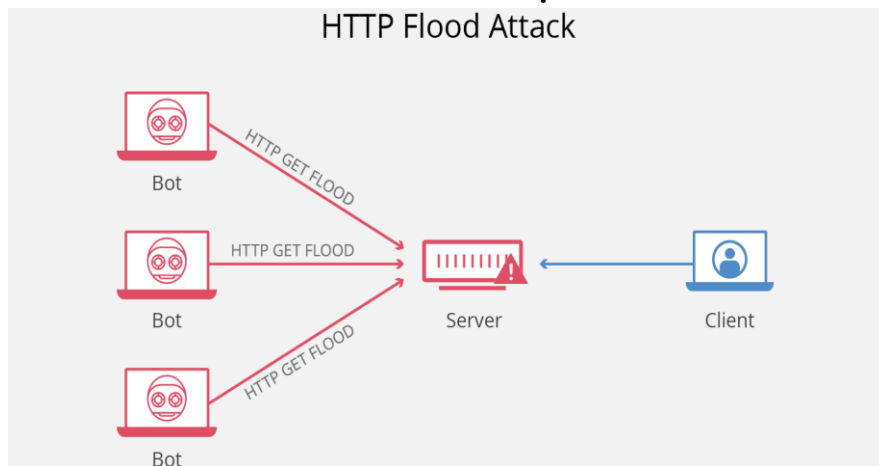
- **Mô tả:**

HTTP Flood là một cuộc tấn công DDoS tầng ứng dụng (Layer 7), nhắm vào máy chủ web bằng cách gửi một lượng lớn yêu cầu HTTP (GET hoặc POST) hợp lệ hoặc gần giống hợp lệ. Mục tiêu là làm quá tải tài nguyên CPU, bộ nhớ hoặc cơ sở dữ liệu của máy chủ, khiến nó không thể phục vụ người dùng thật.

- **Cơ chế:**

- Yêu cầu đơn giản (GET) hoặc phức tạp (POST với truy vấn nặng).
- Thường sử dụng botnet để mô phỏng truy cập từ nhiều nguồn.

- **Hình ảnh minh họa:**



4. DNS Amplification

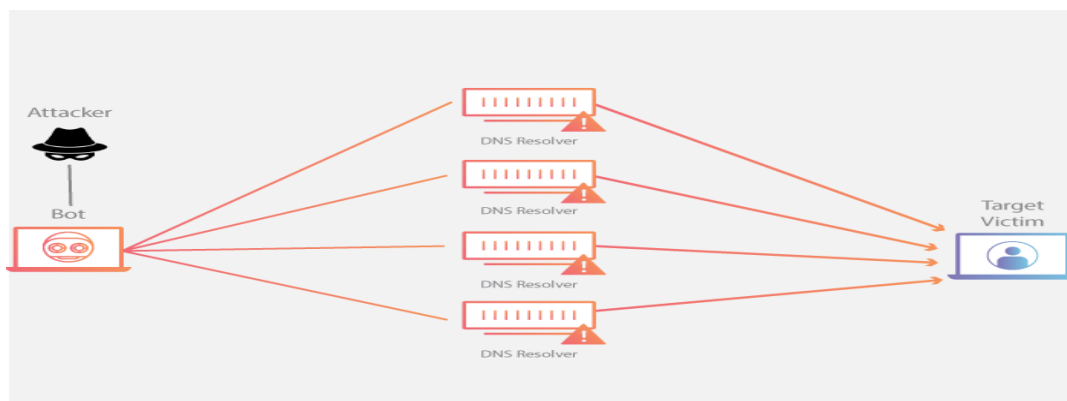
- **Mô tả:**

DNS Amplification là một dạng tấn công DDoS tận dụng các máy chủ DNS mở (open DNS resolvers) để khuếch đại lưu lượng tấn công. Kẻ tấn công gửi các truy vấn DNS nhỏ với địa chỉ IP giả mạo (của nạn nhân) đến máy chủ DNS, yêu cầu phản hồi lớn (ví dụ: truy vấn "ANY"). Phản hồi lớn này được gửi đến nạn nhân, gây quá tải mạng.

- **Cơ chế:**

- Tỷ lệ khuếch đại cao (có thể lên đến 50 lần hoặc hơn).
- Khó truy vết do sử dụng IP giả mạo và máy chủ trung gian.

- **Hình ảnh minh họa:**



2.5 Các ứng dụng trong thực tế (Ví dụ thực tế)

1. Mirai Botnet (2016)

- **Mô tả sự kiện:**

Vào tháng 10/2016, botnet Mirai đã tấn công Dyn – một nhà cung cấp DNS lớn, gây gián đoạn dịch vụ cho các trang web lớn như Twitter, Netflix, PayPal, và GitHub. Mirai lây nhiễm các thiết bị IoT (camera IP, router) bằng cách sử dụng thông tin đăng nhập mặc định, sau đó sử dụng chúng để thực hiện các cuộc tấn công DDoS, bao gồm UDP Flood và DNS Flood.

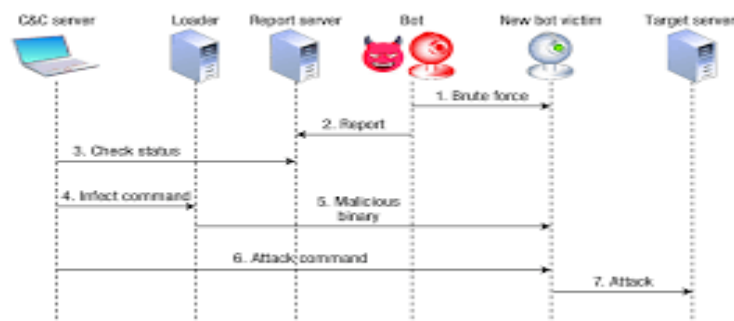
- **Loại tấn công:**

- **UDP Flood:** Gửi lượng lớn gói UDP từ hàng chục nghìn thiết bị IoT để làm tắc nghẽn băng thông.
- **DNS Flood:** Nhắm vào cơ sở hạ tầng DNS của Dyn, làm gián đoạn quá trình phân giải tên miền.

- **Hậu quả:**

- Nhiều dịch vụ trực tuyến lớn bị tê liệt trong hàng giờ.
- Hé lộ lỗ hổng bảo mật của thiết bị IoT.

- **Hình ảnh minh họa:**



2. GitHub 2018

- **Mô tả sự kiện:**

Vào ngày 28/02/2018, GitHub chịu một cuộc tấn công DDoS lớn nhất lịch sử lúc đó, với lưu lượng đỉnh đạt 1.35 Tbps trong khoảng 20 phút. Cuộc tấn công sử dụng kỹ thuật **Memcached Amplification** (tương tự DNS Amplification), khai thác các máy chủ Memcached không được bảo mật để khuếch đại lưu lượng gửi đến GitHub.

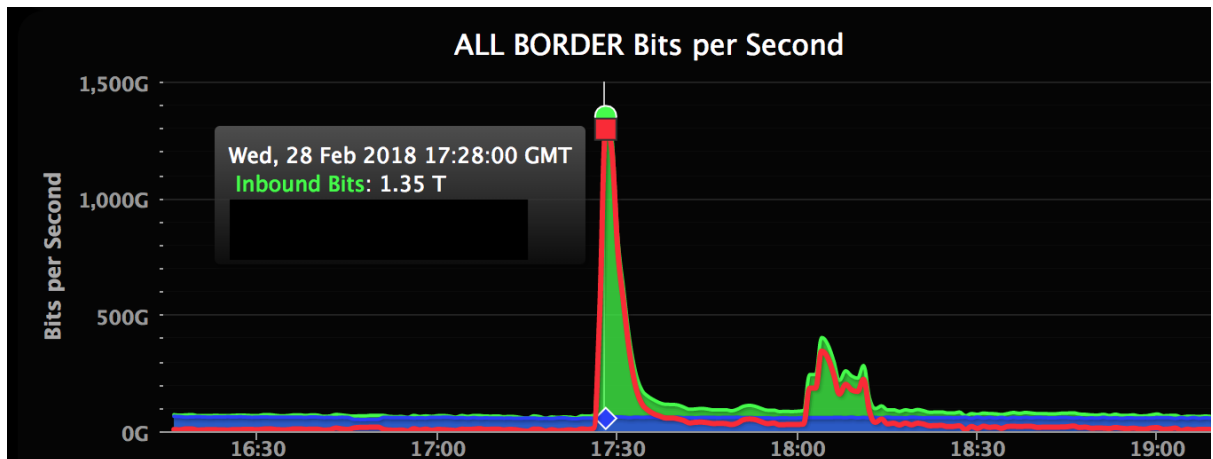
- **Loại tấn công:**

- **DNS Amplification (biến thể):** Dùng Memcached thay vì DNS, nhưng cơ chế tương tự – gửi yêu cầu nhỏ, nhận phản hồi lớn đến nạn nhân.

- **Hậu quả:**

- GitHub nhờ dịch vụ bảo vệ DDoS (Akamai Prolexic) đã giảm thiểu thiệt hại trong 10 phút.
- Tấn công nhấn mạnh nguy cơ từ các máy chủ khuếch đại (amplification servers).

- **Hình ảnh minh họa:**



2.6 Phòng chống thực tiễn

1. Phòng chống SYN Flood

- **Giải pháp:**
 - **SYN Cookies:** Máy chủ tạo mã cookie thay vì lưu trữ trạng thái kết nối "nửa mở", chỉ xác nhận khi nhận ACK hợp lệ.
 - **Tăng kích thước backlog:** Tăng số lượng kết nối tối đa mà máy chủ có thể xử lý.
 - **Lọc IP giả mạo:** Sử dụng tường lửa hoặc router để kiểm tra nguồn IP (Ingress Filtering – BCP 38).
- **Thực tiễn:**
 - Cấu hình tường lửa (như iptables) để giới hạn số lượng SYN mỗi giây từ một nguồn.

2. Phòng chống UDP Flood

- **Giải pháp:**
 - **Giới hạn tốc độ (Rate Limiting):** Giới hạn số gói UDP từ một nguồn IP hoặc trên toàn mạng.
 - **Chặn cổng không cần thiết:** Đóng các cổng UDP không sử dụng trên máy chủ.
 - **Triển khai IDS/IPS:** Hệ thống phát hiện và ngăn chặn xâm nhập để phát hiện lưu lượng bất thường.
- **Thực tiễn:**
 - Sử dụng Cloudflare hoặc Imperva để lọc lưu lượng UDP trước khi đến máy chủ.

3. Phòng chống HTTP Flood

- **Giải pháp:**
 - **Web Application Firewall (WAF):** Lọc các yêu cầu HTTP đáng ngờ dựa trên hành vi (ví dụ: Cloudflare WAF).

- **Thử thách người dùng (Challenge):** Sử dụng CAPTCHA để phân biệt người dùng thật và bot.
- **Cân bằng tải (Load Balancing):** Phân phối lưu lượng qua nhiều máy chủ.
- **Thực tiễn:**
 - Cài đặt Nginx với module `ngx_http_limit_req_module` để giới hạn số yêu cầu HTTP từ một IP.

4. Phòng chống DNS Amplification

- **Giải pháp:**
 - **Đóng máy chủ DNS mở:** Cấu hình DNS resolver chỉ chấp nhận truy vấn từ các nguồn tin cậy.
 - **DNSSEC:** Xác thực nguồn gốc truy vấn để ngăn IP giả mạo.
 - **Lọc lưu lượng:** Chặn các phản hồi DNS lớn không mong muốn tại router hoặc tường lửa.
- **Thực tiễn:** Sử dụng dịch vụ DNS bảo mật như Google Public DNS hoặc Cloudflare 1.1.1.1 với tính năng chống DDoS.

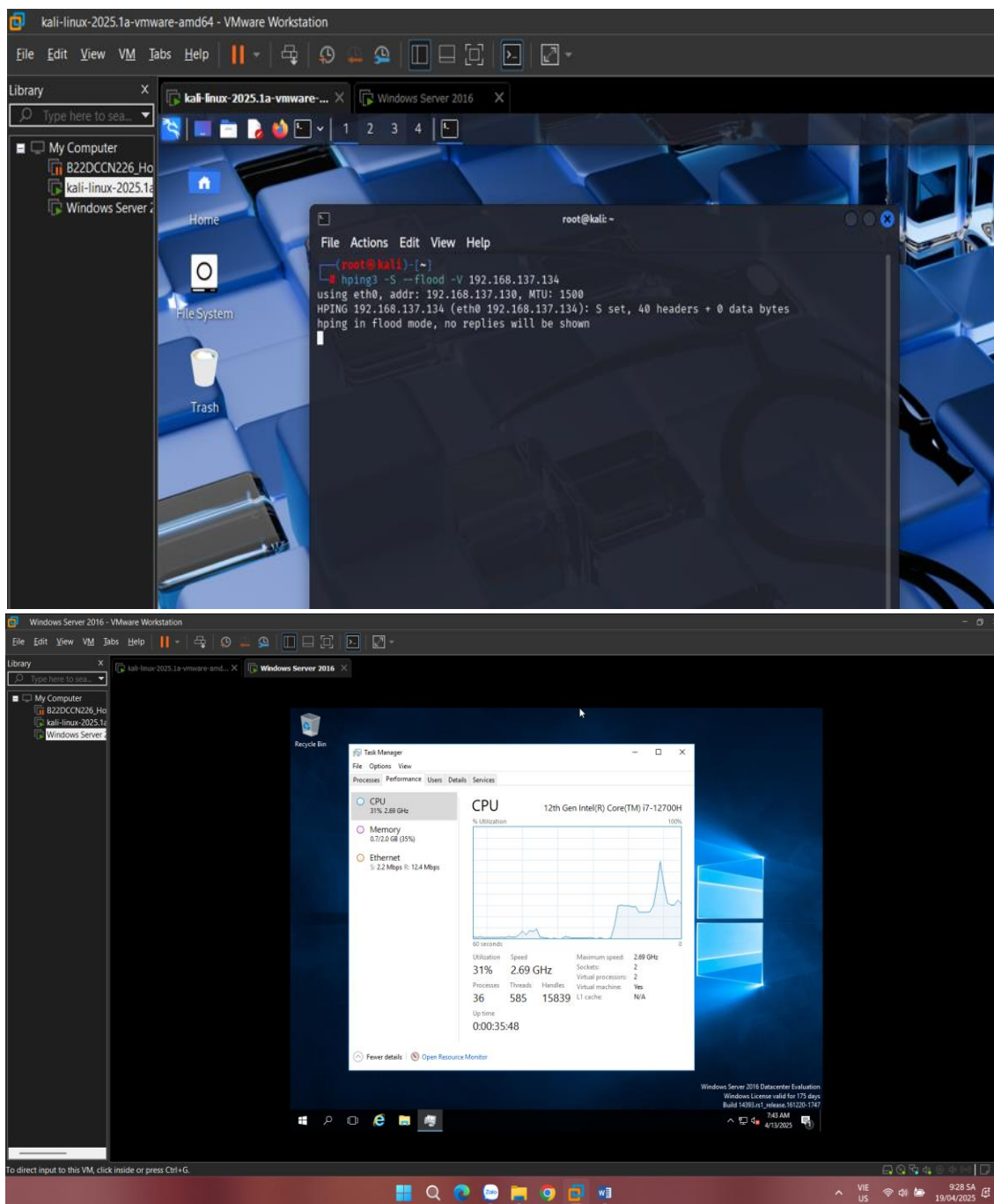
5. Biện pháp tổng quát

- **Sử dụng dịch vụ DDoS Protection:** Các nhà cung cấp như Cloudflare, Akamai, hoặc Imperva có khả năng hấp thụ và lọc lưu lượng tấn công.
- **Giám sát mạng:** Dùng công cụ như Wireshark, Zabbix để phát hiện sớm lưu lượng bất thường.
- **Cập nhật phần mềm:** vá các lỗ hổng trên hệ điều hành và ứng dụng để ngăn khai thác.

2.7 Công cụ minh họa và so sánh

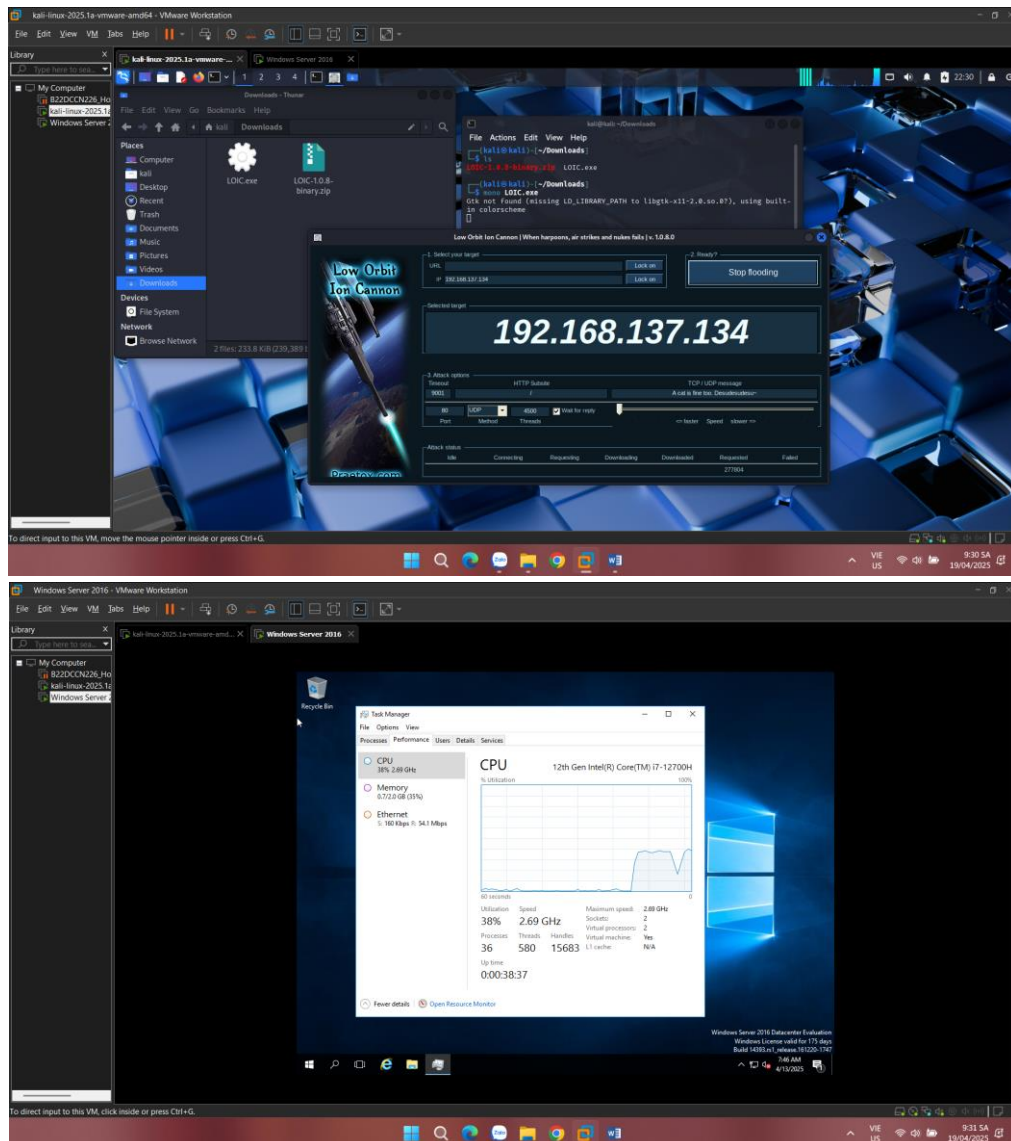
1. Demo tấn công từ chối dịch vụ DoS bằng kỹ thuật Sync Flood và tấn công LOIC

- Địa chỉ IP của máy Target: 192.168.137.134
- Địa chỉ IP của máy Client: 192.168.137.130
- **Kỹ thuật Sync Flood:**
- Câu lệnh: `hping3 -S -flood -v 192.168.137.134`



- **Tấn công LOIC:**

- Máy tấn công sử dụng LOIC v1.0.8 để gửi hàng loạt yêu cầu HTTP đến IP mục tiêu 192.168.137.134. Khi tấn công bắt đầu, CPU trên máy nạn nhân tăng mạnh, cùng với tốc độ mạng nhận vào cao đột biến (trên 10 Mbps). Điều này cho thấy khả năng gây nghẽn tài nguyên dịch vụ khi tấn công HTTP Flood với LOIC.



2. So sánh tính năng, tác động và giới hạn

- Tính năng

Tiêu chí	DoS	DDoS
Nguồn tấn công	Một máy chủ hoặc thiết bị duy nhất.	Nhiều thiết bị trên mạng (botnet, zombie devices).
Cách thực hiện	Gửi lượng lớn yêu cầu hoặc khai thác lỗ hổng dịch vụ.	Phối hợp hàng loạt yêu cầu từ nhiều thiết bị khác nhau.
Mức độ phức tạp	Tương đối đơn giản, dễ phát hiện và chặn.	Phức tạp hơn, khó phát hiện và phân biệt với truy cập hợp lệ.
Triển khai	Một hacker có thể tự thực hiện.	Cần có botnet hoặc mạng thiết bị bị kiểm soát.
Tấn công phân	Không	Có
Ảnh hưởng người tấn công	Khó, vì IP thường là thật.	Dễ hơn vì IP phân tán, có thể giả mạo (IP spoofing).

- Tác động

Tiêu chí	DoS	DDoS
Khả năng làm gián đoạn	Trung bình – phụ thuộc vào tài nguyên tấn công.	Rất cao – dễ dàng đánh sập hệ thống lớn nếu không có phòng thủ.
Tốc độ gây ảnh hưởng	Tương đối nhanh, nhưng có thể bị chặn dễ hơn.	Rất nhanh và mạnh – có thể gây sập trong vài phút hoặc giây.
Mức độ nguy hiểm	Trung bình.	Cao đến rất cao, gây thiệt hại nghiêm trọng về tài chính và uy tín.
Ảnh hưởng đến người dùng	Gián đoạn truy cập, dịch vụ bị treo.	Website sập hoàn toàn, nhiều người dùng không thể truy cập.
Mức độ lan rộng	Giới hạn (chỉ mục tiêu cụ thể).	Có thể ảnh hưởng đến cả mạng lưới và hệ thống liên quan.

- Giới hạn

Tiêu chí	DoS	DDoS
Dễ bị phát hiện	Dễ – vì chỉ có một nguồn phát.	Khó hơn – do lưu lượng từ nhiều địa chỉ khác nhau.
Khả năng bị ngăn chặn	Cao – dễ dàng block IP hoặc	Khó – cần firewall, CDN,

	giới hạn kết nối.	WAF mạnh và hệ thống phân tích hành vi.
Hiệu quả theo thời gian	Không kéo dài – hệ thống có thể hồi phục nhanh nếu chặn được.	Có thể kéo dài hàng giờ, thậm chí nhiều ngày.
Đòi hỏi tài nguyên của kẻ tấn công	Ít tài nguyên – chỉ cần một thiết bị đủ mạnh.	Nhiều tài nguyên – cần xây dựng botnet hoặc thuê dịch vụ DDoS.

3. Kết luận

Báo cáo "Tìm hiểu về các dạng tấn công DoS và DDoS" đã trình bày các nội dung sau:

- **Khái niệm cơ bản** về DoS và DDoS, mục tiêu và tác động đến hệ thống mạng và doanh nghiệp.
- **Phân biệt** giữa DoS (từ một nguồn) và DDoS (từ nhiều nguồn phân tán).
- **Kiến trúc và quy trình tấn công** DoS/DDoS: từ khâu chuẩn bị botnet, giai đoạn tấn công đến thời điểm hệ thống sụp đổ.
- **Phân tích kỹ thuật và điểm yếu** trong từng tầng giao thức (IP, TCP, UDP, DNS, HTTP, NTP, SNMP).
- **Phân loại chi tiết** các loại hình tấn công: SYN Flood, UDP Flood, HTTP Flood, DNS Amplification.
- **Ví dụ thực tế** như Mirai Botnet (2016), GitHub (2018) giúp minh họa tác động tấn công quy mô lớn.
- **Giải pháp phòng chống** chi tiết theo từng loại tấn công, từ cấp hệ thống đến cấp dịch vụ mạng.
- **Demo về tấn công dịch vụ DoS và DDoS**
- **So sánh công cụ tấn công**

4. Tài liệu tham khảo

- [1] Cloudflare. (n.d.). *Denial-of-service (DoS) attack*. Cloudflare.
<https://www.cloudflare.com/learning/ddos/glossary/denial-of-service/>
- [2] Wikipedia contributors. (n.d.). *Denial-of-service attack*. Wikipedia.
https://en.wikipedia.org/wiki/Denial-of-service_attack
- [3] GeeksforGeeks. (2021, August 23). *What is DDoS (Distributed Denial of Service)?*
<https://www.geeksforgeeks.org/what-is-ddosdistributed-denial-of-service/>
- [4] GeeksforGeeks. (2021, August 30). *Difference between DoS and DDoS attack*.
<https://www.geeksforgeeks.org/difference-between-dos-and-ddos-attack/>
- [5] Rathore, H., Sharma, A., & Kumar, S. (2014). Review: Clustering mechanisms of distributed denial of service attacks. *ResearchGate*. <https://www.researchgate.net/publication/265053091>
- [6] Gandotra, E., Bansal, D., & Sofat, S. (2017). Denial of service attacks: defences and research challenges. *ResearchGate*. <https://www.researchgate.net/publication/312575070>
- [7] Antonakakis, M., April, T., Bailey, M., Bernhard, M., Bursztein, E., Cochran, J., ... & Zhao, Y. (2017). *Understanding the Mirai Botnet*. In Proceedings of the 26th USENIX Security Symposium (pp. 1093–1110).
<https://www.usenix.org/system/files/conference/usenixsecurity17/sec17-antonakakis.pdf>
- [8] GitHub. (2018). *Mirai Source Code*. GitHub Repository.
<https://github.com/jgamblin/Mirai-Source-Code>
- [9] Krebs, B. (2016). *KrebsOnSecurity Hit With Record DDoS*.
<https://krebsonsecurity.com/2016/09/krebsonsecurity-hit-with-record-ddos/>
- [10] Tô,N,N,Quang (n.d.). *An toàn mạng máy tính* Đại học Quốc gia TP.HCM.
<https://feuer.vn/wp-content/uploads/2014/12/An-toan-mang-may-tinh-Bai-1.pdf>